

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
ИТМО
ITMO University

ЛАБОРАТОРНАЯ РАБОТА №2

По дисциплине Администрирование платформ на ОС Linux

Тема работы Nginx

Обучающийся Сакулин Иван Михайлович

Факультет Факультет прикладной информатики

Группа K3221

Направление подготовки 11.03.02 Инфокоммуникационные технологии и
системы связи

Образовательная программа Программирование в инфокоммуникацион-
ных системах

Обучающийся

(дата)

(подпись)

Сакулин И.М.

(Ф.И.О.)

Руководитель

(дата)

(подпись)

Береснев А.Д.

(Ф.И.О.)

СОДЕРЖАНИЕ

Стр.

ВВЕДЕНИЕ	3
1 ХОД РАБОТЫ.....	4
1.1 Подготовка.....	4
1.2 Написание конфигурации	6
1.3 Организуем DOS атаку	12
2 ВОПРОСЫ	14
ЗАКЛЮЧЕНИЕ	15

ВВЕДЕНИЕ

Цель работы: развернуть Nginx для веб-приложения и применить бестпрактис в конфигурации.

Задачи:

- установить нужные зависимости, библиотеки и librespeed;
- настроить конфигурацию nginx;
- провести DOS атаку slowloris.

1 ХОД РАБОТЫ

1.1 Подготовка

По готовым командам из задания к лабораторной была обновлена база данных пакетного менеджера **apt**, установлены необходимые утилиты (**nginx**, **git**, **node**), создаём директорию для приложения, клонируем репозиторий с приложением, устанавливаем необходимые зависимости (рисунок 1).

```
1 sudo apt update
2 sudo apt install -y nginx nodejs npm git nload
3 sudo mkdir -p /opt/librespeed
4 sudo chown $USER:$USER /opt/librespeed
5 cd /opt/librespeed
6 git clone -b node https://github.com/librespeed/speedtest.git
7 cd speedtest/src
8 npm install
9 nano SpeedTest.js
```

Рисунок 1 — Установка и настройка

Идея каждый раз запускать все сервисы и держать открытый терминал для их работы была отвергнута. Чтобы исправить это неудобство был написан шаблонный **unit**, который позволяет используя выражение **speedtest@i** открывать сервисы на нужных портах (рисунок 2).

Юнит-файл сервиса был помещён в соответствующую директорию и активирован (рисунок 3). Были инициализированы три сервиса на портах 8888, 8889 и 8890.

Активность сервисов можно посмотреть командой.

```
sudo systemctl status "speedtest@*"
```

```
ivan@sakulinim: ~
GNU nano 7.2 speedtest@.service
[Unit]
Description=Template "speedtest@i" by SakulinIM
After=network.target
After=nginx.service

[Service]
Type=simple
ExecStart=/usr/bin/node /opt/librespeed/speedtest/src/SpeedTest.js %i
Restart=on-failure
RestartSec=5
KillMode=mixed
TimeoutStopSec=5

User=nobody
Group=nogroup

[Install]
WantedBy=multi-user.target

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

Рисунок 2 — Написание unit-сервиса

```
ivan@sakulinim:~$ ls
app.py  cert  duckdns  speedtest@.service
ivan@sakulinim:~$ sudo cp speedtest@.service /etc/systemd/system/
ivan@sakulinim:~$ sudo systemctl daemon-reload
ivan@sakulinim:~$ sudo systemctl enable speedtest@8888.service
Created symlink /etc/systemd/system/multi-user.target.wants/speedtest@8888.servic
e -> /etc/systemd/system/speedtest@.service.
Unit /etc/systemd/system/speedtest@.service is added as a dependency to a non-ex
istent unit multi-user.target.
ivan@sakulinim:~$ sudo systemctl start speedtest@8888.service
ivan@sakulinim:~$ curl -v http://localhost:8888
* Host localhost:8888 was resolved.
* IPv6: ::1
* IPv4: 127.0.0.1
* Trying [::1]:8888...
* connect to ::1 port 8888 from ::1 port 33490 failed: Connection refused
* Trying 127.0.0.1:8888...
* Connected to localhost (127.0.0.1) port 8888
> GET / HTTP/1.1
> Host: localhost:8888
> User-Agent: curl/8.5.0
> Accept: */*
>
< HTTP/1.1 200 OK
```

Рисунок 3 — Добавление unit-сервиса (пример с 8888)

1.2 Написание конфигурации

Конфигурация была написана согласно требованиям и с использованием certbot.

В контексте `http` был определён пул серверов для балансировки, включено отображение версии Nginx, определён словарь для определения заголовка `user-agent` ботов, менеджеров загрузки и прочих автоматизированных клиентов.

```
1 server_tokens off;
2
3 map $http_user_agent $bad_bot {
4     default 0;
5     ~*msnbot|scrapbot|wget|python|java|httpclient|okhttp|winhttp|
6     ↪ HTTrack|WebZIP|FlashGet|GetRight|qqmail|curl 1;
7 }
8
9 upstream backend_servers {
10     server 127.0.0.1:8888;
11     server 127.0.0.1:8889;
12     server 127.0.0.1:8890;
13 }
```

Был определён контекст `server`. Сервер прослушивает порты 80 и 443. Если доменное имя не совпадает, возвращает пустой ответ. Если запрос идёт по схеме `http`, производим редирект на `https`.

```
1 server {
2     listen 80;
3     listen 443 ssl;
4     server_name otz.duckdns.org;
5
6     if ($host != otz.duckdns.org) {
7         return 444;
8     }
9 }
```

```
10     if ($scheme = 'http') {
11         return 301 https://$host$request_uri;
12     }
13
14     root /opt/librespeed/speedtest/src/public;
```

Были определены заголовки безопасности и скрыт заголовок Server.

```
1     add_header Strict-Transport-Security 'max-age=31536000; includeSubDomains;
    ↪ preload';
2     add_header X-Frame-Options SAMEORIGIN always;
3     add_header X-Content-Type-Options nosniff;
4     add_header X-XSS-Protection "1; mode=block";
5     add_header Referrer-Policy "strict-origin-when-cross-origin" always;
6     add_header Permissions-Policy "geolocation=(), camera=(), microphone=()"
    ↪ always;
7     add_header Content-Security-Policy "default-src 'self'; script-src 'self'
    ↪ 'unsafe-inline'; style-src 'self' 'unsafe-inline';" always;
8
9     more_clear_headers 'Server';
```

Была введена проверка заголовка `user-agent` и задан редирект на страницы с ошибками.

```
1     if ($bad_bot) {
2         return 403;
3     }
4
5     proxy_intercept_errors on;
6     error_page 403 404 500 502 503 504 /error.html?code=$status;
```

Были введены ограничения против переполнения буфера.

```
1     client_body_buffer_size 128k;
2     client_header_buffer_size 1k;
3     client_max_body_size 128m;
4     large_client_header_buffers 2 1k;
```

Был определён основной location с проксированием трафика на пул серверов, фильтрацией http методов, передачей заголовков с ip.

```
1     location / {
2         limit_except GET POST {
3             deny all;
4         }
5
6         proxy_pass http://backend_servers;
7
8         proxy_set_header Host $host;
9         proxy_set_header X-Real-IP $remote_addr;
10        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
11        proxy_set_header X-Forwarded-Proto $scheme;
12    }
```

Были переопределены страницы с ошибками.

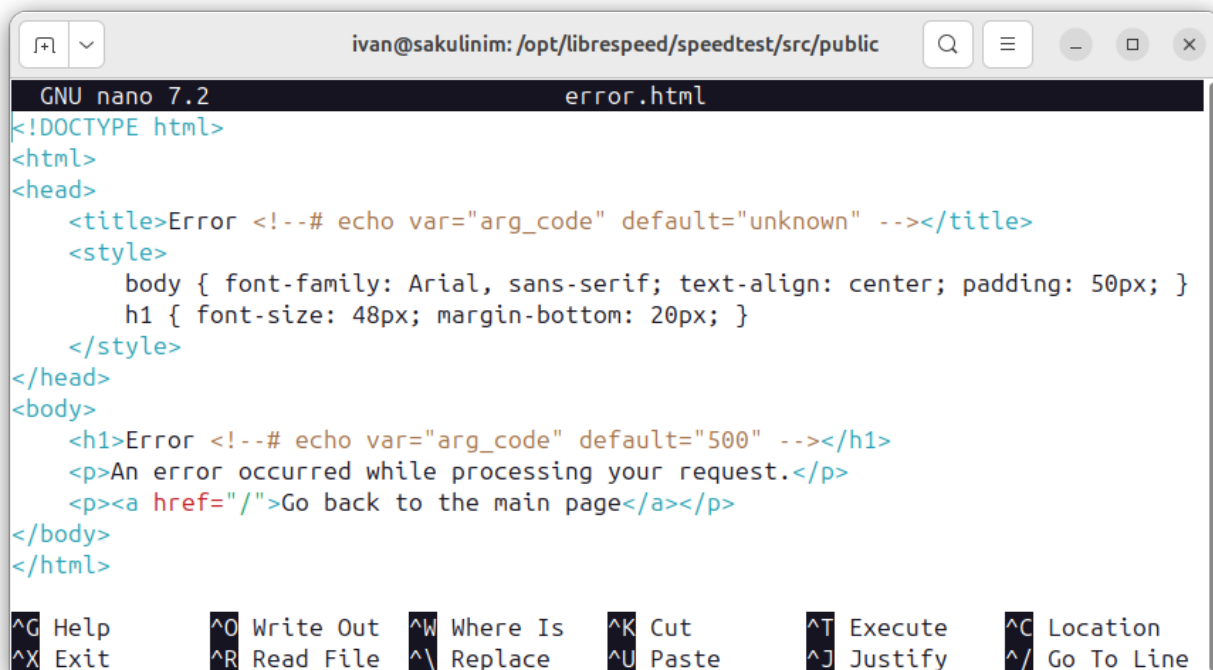
```
1     location = /error.html {
2         internal;
3         root /opt/librespeed/speedtest/src/public;
4         ssi on;
5     }
```

Certbot установил необходимые настройки сертификатов.

```
1     ssl_certificate /etc/letsencrypt/live/otz.duckdns.org/fullchain.pem; #
    ↪ managed by Certbot
2     ssl_certificate_key /etc/letsencrypt/live/otz.duckdns.org/privkey.pem; #
    ↪ managed by Certbot
3     include /etc/letsencrypt/options-ssl-nginx.conf; # managed by Certbot
4     ssl_dhparam /etc/letsencrypt/ssl-dhparams.pem; # managed by Certbot
5 }
```

Кастомная страница ошибок и иконка сайта

Чтобы скрыть упоминание nginx со страницы ошибок и добавить красивый значок в `/src/public` директории приложения были добавлены `error.html` и `favicon.ico`.



```
ivan@sakulinim: /opt/librespeed/speedtest/src/public
GNU nano 7.2 error.html
<!DOCTYPE html>
<html>
<head>
  <title>Error <!--# echo var="arg_code" default="unknown" --></title>
  <style>
    body { font-family: Arial, sans-serif; text-align: center; padding: 50px; }
    h1 { font-size: 48px; margin-bottom: 20px; }
  </style>
</head>
<body>
  <h1>Error <!--# echo var="arg_code" default="500" --></h1>
  <p>An error occurred while processing your request.</p>
  <p><a href="/">Go back to the main page</a></p>
</body>
</html>

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

Рисунок 4 — Код страницы ошибки

Error 404

An error occurred while processing your request.

[Go back to the main page](#)

Рисунок 5 — Проверка в браузере

Проверка настроек

Сайт и его работоспособность были проверен при стандартном подключении в браузере (рисунок 6). Было установлено безопасное подключение с родительским сертификатом Let's Encrypt. Тесты скорости показали предельные для тарифа показатели, ip был успешно определён.

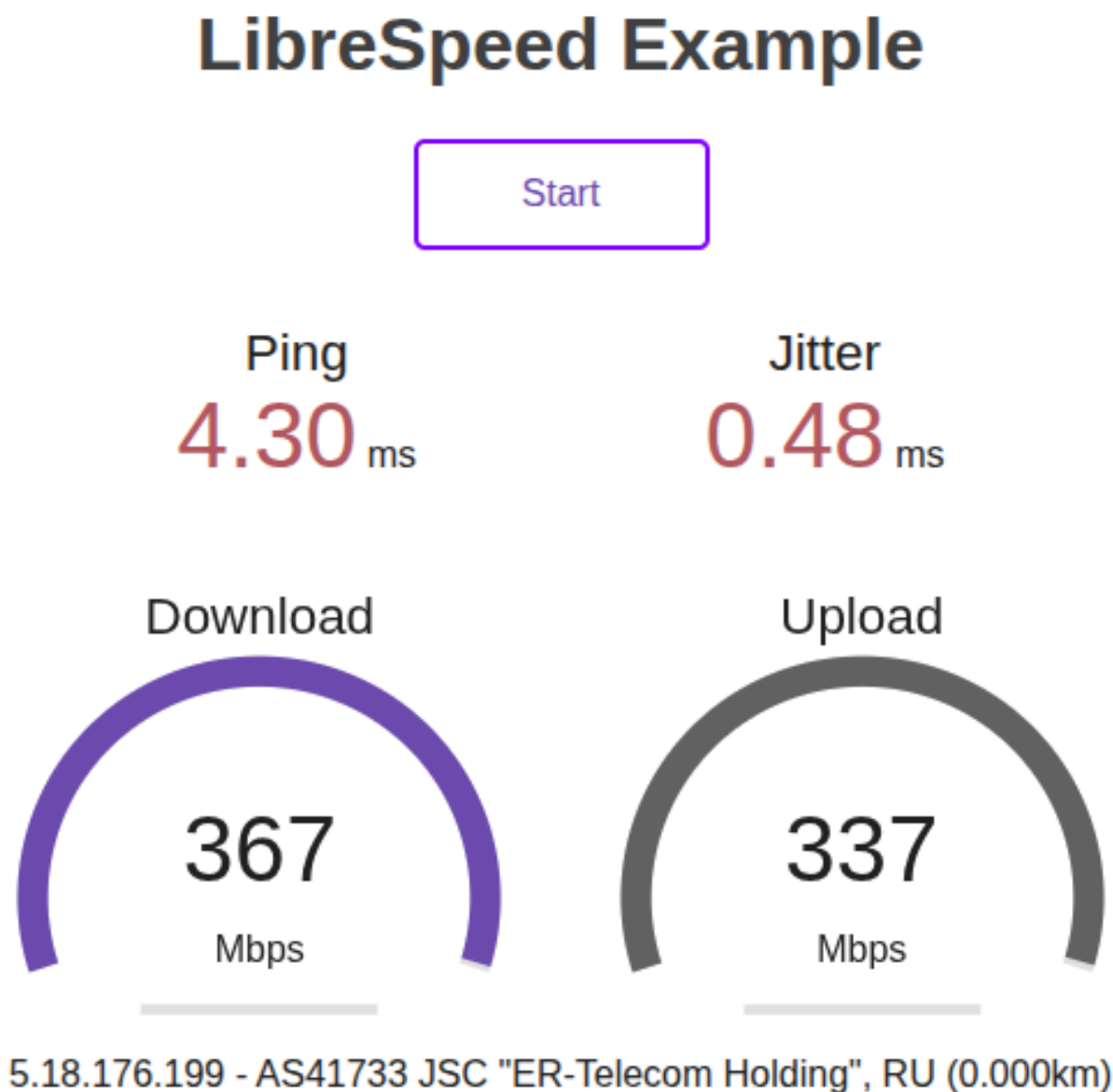


Рисунок 6 — Проверка в браузере

Также были проверены заголовки ответов (рисунок 7). Упоминания nginx в них не обнаружено.

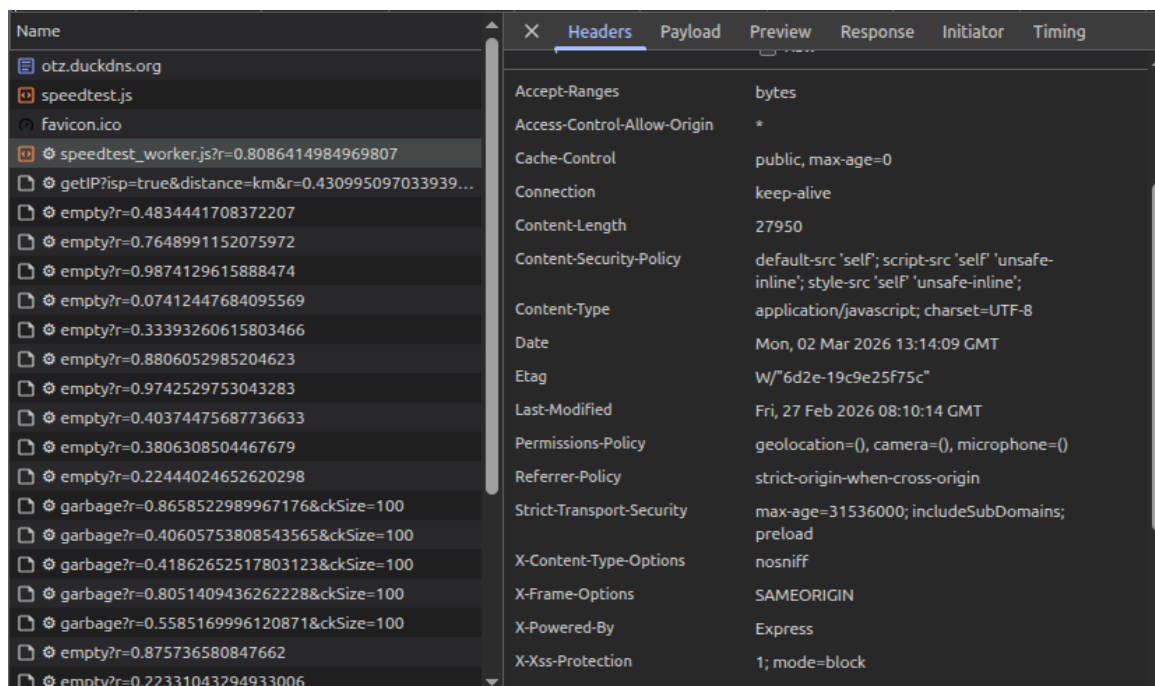


Рисунок 7 — Заголовки ответов

Переадресация с http на https работает, ответы только по доменному имени, по ip сервер не отвечает (рисунок 8).

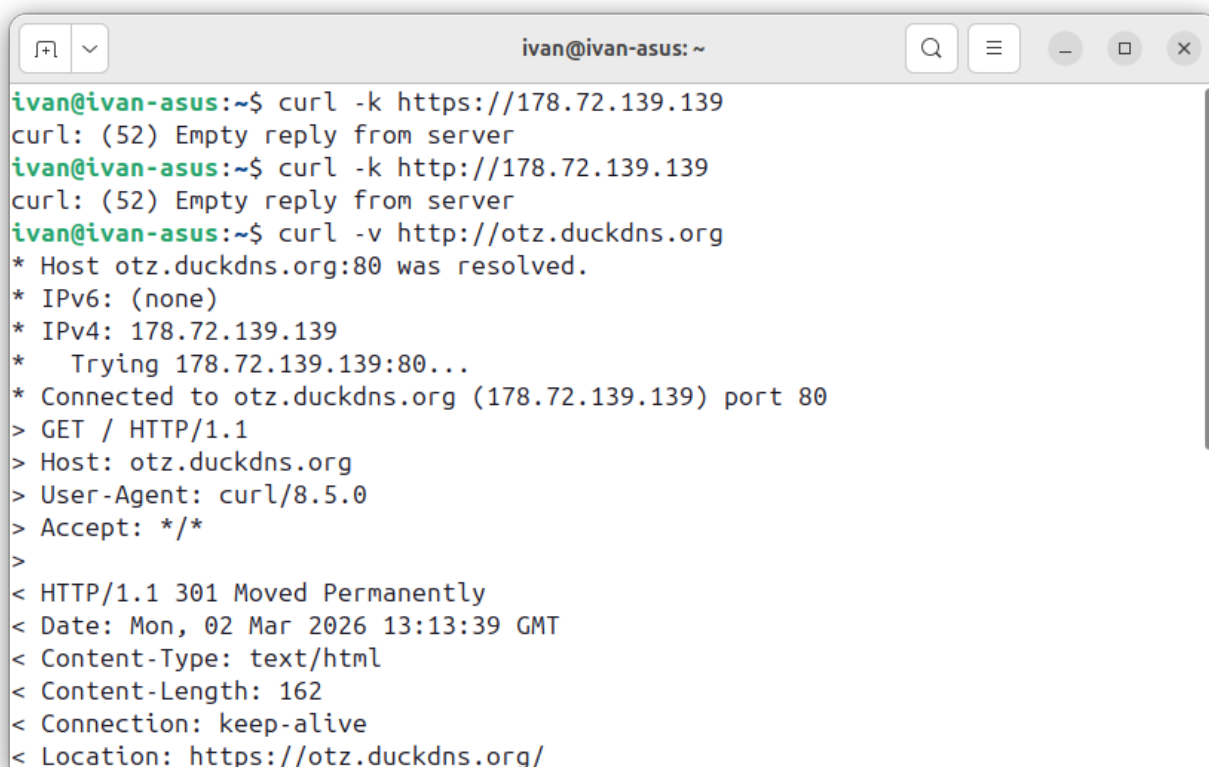


Рисунок 8 — Тестирование различных подключений

1.3 Организуем DOS атаку

Была запущена атака: на 800 соединений и 3 запущенных теста скорости. Ошибок не было обнаружено, тесты скорости тоже работали (рисунок 9).

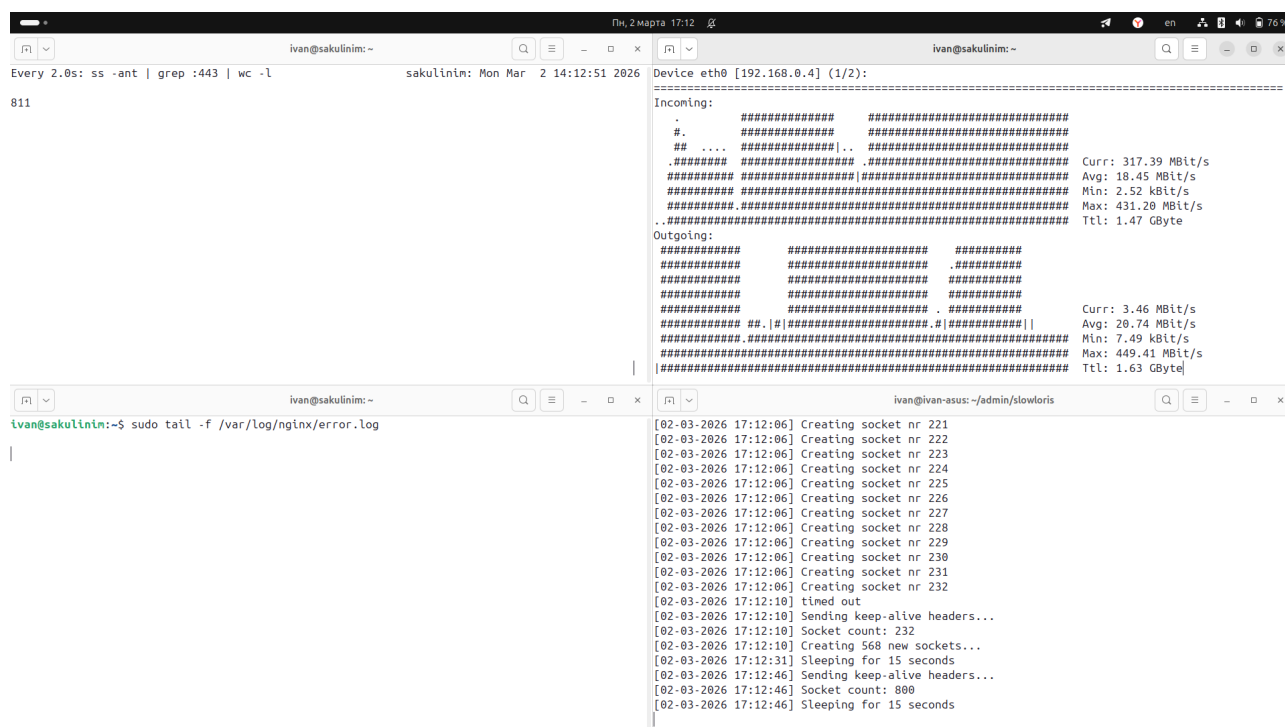


Рисунок 9 — DOS атака до изменений

Для защиты от DOS атак были добавлены несколько настроек с timeout (рисунок 10)

```
1 client_header_timeout 10s;
2 client_body_timeout 10s;
3 send_timeout 10s;
4 keepalive_timeout 10s;
5 reset_timedout_connection on;
```

Рисунок 10 — Защита от slowloris

После обновления конфига ошибок всё также не было, но тесты скорости стали работать на полную (рисунок 11)

2 ВОПРОСЫ

1. Зачем нужна балансировка?

Балансировка нагрузки распределяет входящий трафик между несколькими серверами, что позволяет равномерно использовать ресурсы, обеспечивает отказоустойчивость (если часть серверов упадёт, остальные будут поддерживать работу), позволяет масштабировать серверную часть для обслуживания большего количества пользователей.

2. Убейте процессы бэкендов и откройте сайт. Что произошло и как вы это объясните?

Когда сервисы выключены nginx как reverse проху не может перенаправить трафик и выдаёт ошибку 502 bad gateway.

Error 502

An error occurred while processing your request.

[Go back to the main page](#)

Рисунок 12 — Ошибка при выключенных backend сервисах

ЗАКЛЮЧЕНИЕ

В ходе работы были установлены нужные зависимости, библиотеки и librespeed, создан unit-service для запуска бекендов, настроена конфигурация nginx, добавлена страница ошибок, проведена DOS атака slowloris.